GitHub Trending Top 10

每日热门开源项目深度解读

2026-10-23

今日榜单

1 **cloudflare/security-audit-skill** JavaScript
A coding-agent skill for multi-phase security audits with independently verified... 4天

2 **php/php-src** C
The PHP Interpreter 2天

3 **anthropics/knowledge-work-plugins** Python
Open source repository of plugins primarily intended for knowledge workers to us... 2天

4 **NVIDIA/OpenShell** Rust
OpenShell is the safe, private runtime for autonomous AI agents. NEW

5 **Renhuai123/ziwei-doushu** TypeScript
紫微斗数开源排盘引擎 — 基于倪海厦《天纪》体系，含完整排盘算法、四化系统、格局知识… NEW

6 **SnailSploit/Claude-Red** Python
claude-red is a curated library of offensive security skills designed for the Cl... NEW

7 **OpenBMB/VoxCPM** Python
VoxCPM2: Tokenizer-Free TTS for Multilingual Speech Generation, Creative Voice D... NEW

8 **nodejs/node** JavaScript
Node.js JavaScript runtime ✨🐢🚀✨ NEW

#1 JavaScript 连续 4 天

security-audit-skill

A coding-agent skill for multi-phase security audits with independently verified, machine-readable findings

Stars **41,142** Forks **2,564** Today **+2,706**

https://github.com/cloudflare/security-audit-skill

项目简介：这是 Cloudflare 开源的一个"技能包"（skill），本质是一套给编程 Agent 用的安全审计方法论与提示词工程集合。它把 AI 编码助手改造成一个结构化的安全审计员，通过多阶段、多 Agent 协作来发现代码中的安全漏洞，并产出可机器校验的审计结论。项目源自 Cloudflare 内部的漏洞发现系统，是其单仓库起点版本。

核心功能：一是六阶段审计流程（侦察→覆盖驱动的狩猎→候选验证→结构化输出→独立记录复核→目标中立报告），每阶段有明确的产物文件；二是"证伪优先"的验证机制，每个候选漏洞交给全新验证 Agent 尝试推翻，结论分为 confirmed/needs_validation/rejected 三档；三是零依赖的校验脚本（validate-findings.cjs、validate-coverage-ledger.cjs），用 JSON Schema 保证产出格式合法；四是覆盖账本（coverage-ledger）机制，支持对同一仓库多次审计的增量叠加，避免把陈旧或未解决的工作当成"已覆盖"。

适用场景：主要面向安全工程师、红队成员，以及希望用 AI 辅助做代码安全审查的开发团队。典型用法是在目标代码库中启动编码 Agent，直接说"对这个代码库做安全审计"。它覆盖的攻击面非常广——从内存安全、Web 协议与认证、客户端 DOM 注入，到 AI/LLM 提示注入、供应链、云部署、数据隔离等，适合对中大型项目做系统性、可追溯的安全体检。

技术亮点：最值得关注的是它的"独立验证"设计——不是让同一个 Agent 自说自话，而是用隔离的、全新的 Agent 去复核前一个 Agent 的结论，通过"尝试证伪"来提升可信度，这直接回应了 LLM 容易产生幻觉和误报的痛点。其次是把审计过程拆成可校验的结构化产物（architecture.md、coverage-ledger.json、findings.json），并用脚本强制 schema 合规，让 AI 的输出从"一段文字"变成"可审计的数据"。此外，攻击类目按目标类型分文件组织（如 AI-AND-LLM.md、MEMORY-SAFETY-AND-BINARY.md），体现了很强的工程化和可扩展性。

上手建议：先用 `npx skills add` 安装技能，在一个你熟悉的开源仓库上跑一次完整审计，重点观察 coverage-ledger 和 findings.json 的生成过程，理解六阶段的流转逻辑。想深入的话，建议先读 SKILL.md 和 VALIDATION-AND-REPORTING.md 掌握核心原则，再看 ATTACK-CLASSES.md 了解攻击

类目组织方式；贡献方向可以是新增攻击类目文件、改进验证脚本的测试用例，或针对特定技术栈补充狩猎提示词。

#2 C 连续 2 天

php-src

The PHP Interpreter

Stars **41,480** Forks **8,346** Today **+722**

https://github.com/php/php-src

项目简介：php/php-src 是 PHP 编程语言的官方解释器源码仓库，也就是 PHP 语言本身的“母体”。它解决的问题是提供一个快速、灵活、务实的通用脚本语言运行时，尤其针对 Web 开发场景，支撑从个人博客到全球顶级网站的各种应用。

核心功能：提供 PHP 语言的完整解释执行能力（词法/语法解析、编译为 opcode、Zend 虚拟机执行）；内置大量标准扩展（如 SPL、PDO、JSON、mbstring 等）；提供 CLI、FPM、Apache 模块等多种 SAPI 运行方式；自带完善的测试套件（`make test`）与持续集成/模糊测试保障；支持通过 PIE/PECL 生态扩展功能。

适用场景：绝大多数使用者是“用 PHP 写应用”的开发者，他们通常安装预编译包而非直接编译本仓库；真正直接使用本仓库的是 PHP 内核贡献者、扩展开发者、发行版打包者，以及需要定制编译（如开启调试、裁剪扩展、嵌入式集成）的团队。

技术亮点：核心用 C 实现，采用 Zend 引擎（编译为 opcode 后由虚拟机执行）与引用计数+循环垃圾回收的内存管理机制；构建链依赖 autoconf/bison/re2c，体现经典 Unix 工具链风格；同时接入 OSS-Fuzz 做模糊测试，说明其对安全性与健壮性的重视；测试体系支持并行执行，工程化程度高。

上手建议：若只是想使用 PHP，直接下载预编译包即可，无需碰本仓库；若想编译或贡献代码，先按 README 在 Ubuntu/Fedora/macOS 上装好 autoconf、bison、re2c 等依赖，用 `./buildconf && ./configure --enable-debug && make -j$(nproc)` 跑通构建，再执行 `make test` 验证环境。贡献方面，修 bug 无需 RFC，可直接 fork 提 PR；新增特性则需先走 wiki.php.net 的 RFC 流程并获得开发者投票通过。

#3 Python 连续 2 天

knowledge-work-plugins

Open source repository of plugins primarily intended for knowledge workers to use in Claude Cowork

Stars **31,999** Forks **3,558** Today **+643**

https://github.com/anthropics/knowledge-work-plugins

项目简介：这是 Anthropic 官方开源的一套 Claude 插件集合，专门为知识工作者（销售、法务、财务、市场等）打造，让 Claude 从通用助手变成懂具体岗位的“专家”。它解决的是通用 AI 助手不了解企业工具链、术语和工作流程，导致输出不专业、不一致的问题。

核心功能：一是内置 11 个岗位插件（生产力、销售、客服、产品、市场、法务、财务、数据、企业搜索、生物研究、插件管理），每个都打包了对应职能的技能、连接器和斜杠命令；二是通过 MCP 连接器打通 Slack、Notion、Jira、HubSpot、Snowflake 等主流企业工具，实现跨系统取数；三是提供 `/sales:call-prep`、`/data:write-query` 这类显式斜杠命令和自动触发的 Skills 机制；四是支持企业基于自身工具、术语和流程二次定制插件。

适用场景：主要面向企业里的知识型岗位——销售做客户调研和通话准备、法务审合同和 NDA、财务做对账和报表、产品经理写规格和路线图、数据分析师写 SQL 出图表等。也适合想要把 Claude 深度嵌入团队工作流、统一输出标准的组织。

技术亮点：采用统一的文件化插件结构（manifest + `.mcp.json` + commands + skills），Skills 编码领域最佳实践并自动触发，Commands 提供显式调用，连接层基于 MCP 协议标准化对接外部工具，整体可读可改、易于定制。

上手建议：普通用户可直接在 Cowork 中从 claude.com/plugins 安装，或在 Claude Code 里执行 `claude plugin marketplace add anthropics/knowledge-work-plugins` 后安装指定插件；开发者建议先读某个插件（如 productivity）的目录结构和 skills 写法，再参考 cowork-plugin-management 插件为自家团队定制。

#4 Rust NEW

OpenShell

OpenShell is the safe, private runtime for autonomous AI agents.

Stars **18,401** Forks **1,856** Today **+1,240**

https://github.com/NVIDIA/OpenShell

项目简介：OpenShell 是 NVIDIA 推出的开源 AI Agent 安全运行时，用 Rust 编写，核心目标是让自主 AI Agent 能够读写文件、安装软件包、调用 API 和使用凭证，同时不给予它们对用户数据、密钥和网络的无限访问权限。它通过"策略声明 + 运行时强制执行"的方式，把 Agent 的能力边界交给用户显式定义。

核心功能： - **内核级沙箱隔离**：每个 Agent 运行在独立沙箱中，内核控制其可访问的文件、可发起的系统调用，所有网络连接在离开沙箱前都经过策略检查。 - **凭证隔离**：Agent 永远看不到真实凭证，OpenShell 仅在发往已批准端点的请求中注入凭证。 - **形式化验证的策略变更**：策略变更生效前，用形式化验证预判会新增哪些风险访问（如带凭证访问新主机），高风险变更需人工审核。 - **网关控制平面**：统一管理沙箱、策略与访问，支持 Kubernetes 部署（Helm）及中间件/拦截器/计算驱动等扩展点。

适用场景：适合需要让 AI Agent 真正"动手做事"（读文件、装依赖、连外部 API）但又必须控制风险的团队，典型如企业内部的自动化运维 Agent、需要访问敏感数据的编码助手、以及多 Agent 集群（fleets）的集中治理场景。安全合规要求高的组织尤其受益。

技术亮点：最值得注意的是"内核插桩 + 形式化验证"的双层设计——前者保证运行时不可绕过，后者把安全审查前移到策略变更阶段，这在 Agent 安全领域较为少见。选择 Rust 实现也契合其安全关键定位；此外项目同时提供 Python SDK（PyPI）和面向编码 Agent 的 Skills，生态铺得很开。18k 星标、单日新增 1240 也说明它踩中了"Agent 安全"这个当下热点。

上手建议：按 README 用一行 `curl` 脚本安装 CLI 并创建默认沙箱，然后跟随"Run Your First Agent"教程跑通 OpenCode + OpenRouter 的完整流程，重点体会"Agent 请求新权限 → 人工批准"的交互。想深入可读架构文档理解 gateway/supervisor/sandbox 三者关系；贡献方面，扩展性文档（middleware、interceptors）和 `skills/` 目录是较好的切入点。

#5 TypeScript NEW

ziwei-doushu

紫微斗数开源排盘引擎 — 基于倪海厦《天纪》体系，含完整排盘算法、四化系统、格局知识库、古籍原文数据

Stars **6,671** Forks **1,366** Today **+547**

https://github.com/Renhuai123/ziwei-doushu

项目简介：这是一个用 TypeScript 实现的紫微斗数开源排盘引擎，基于倪海厦《天纪》教学体系，把传统命理排盘算法、四化系统、格局知识库和古籍原文数据工程化。它解决的核心问题是：让紫微斗数从"手工排盘+口传心授"变成可编程、可验证、可批量生成解读的数据基础设施。

核心功能：①完整排盘算法（含真太阳时校正、中国 1986–1991 夏令时、农历闰月边界处理、十二神煞、运限含童限）；②四化系统与星曜亮度流派配置；③格局知识库与《紫微斗数全书》古籍引证（405 处逐字可查）；④v4.0 解读数据集——67.5 万张命盘 × 13 维 = 877 万段解读、约 204 亿字，按年份分 77 个文件发布；⑤倪师《天纪》原话 1848 条语料，每条标注集数与时间戳可回放。

适用场景：命理研究者与爱好者做排盘验证和流派对照；开发者把排盘能力嵌入 App、小程序或 AI 解读产品；数据/算法研究者拿大规模命盘-解读配对数据做文本生成、知识图谱或规则引擎实验；教学场景下用可回放的原话语料做溯源式学习。

技术亮点：把"玄学"做成了可回归测试的软件工程——5 条排盘回归测试 + GitHub Actions CI，用金标准盘逐宫核对星曜落宫与亮度；数据集发布前 77 个文件逐个解压与原始数据逐字节比对；断语校正遵循"查不到出处就删、不会发生的四化就删、两头说的句子按盘只留成立的一种"这类可审计规则；依赖从 483 个精简到 185 个并清零安全告警，工程洁癖相当罕见。此外对六亲判断的局限性做了诚实标注并附倪师原话出处，这种"承认边界"的态度在同类项目中很少见。

上手建议：先 `git clone` 后 `npm test` 跑通 5 条回归，再读 `algorithm.ts`（641 行）理解排盘主流程，配合 `true-solar-time.ts`、`dst-cn.ts`、`lunar-solar.ts` 三个模块搞清时间校正链路。数据侧建议先下单个年份的 v4.0 分卷而非 56.6 GB 总包。贡献方面注意开源边界：断语库不开源，可贡献的是引擎、测试、城市经度数据、文档勘误；提 PR 前先看贡献指南和 issue 模板，积压 issue 已清到 4 条，维护节奏较明确。

#6 Python NEW

Claude-Red

claude-red is a curated library of offensive security skills designed for the Claude skills system. Each skill is a structured SKILL.md file that primes Claude with expert-level methodology for a specific attack surface — from SQLi to shellcode, EDR evasion to exploit development.

Stars **8,133** Forks **1,075** Today **+209**

https://github.com/SnailSploit/Claude-Red

项目简介：Claude-Red 是一个面向 Claude Skills 系统的进攻性安全技能库，通过结构化的 SKILL.md 文件把 Claude 塑造成具备专家级方法论的红队操作员。它解决的核心问题是：通用大模型在渗透测试等专业安全场景中缺乏系统化的攻击面知识和操作路径，而该项目用“可插拔技能包”的方式弥补这一缺口。

核心功能：项目收录了 78 个技能、覆盖 23 个安全类别，从 Web 漏洞（SQLi、OWASP Top 10）到二进制漏洞利用开发、EDR 规避、ADCS 滥用、无线攻击、云攻击路径等。每个技能包含具体技术、工具链、边界情况和提权/横向移动路径；技能按对话触发词按需加载，不占用未使用技能的上下文；同时提供 `install.sh` 脚本和稀疏检出方式，支持按类别或单个技能安装。

适用场景：主要面向授权红队评估、漏洞赏金 triage、安全研究、CTF 备赛和操作员培训。使用者通常是渗透测试人员、安全研究员或红队工程师，他们希望在 Claude 辅助下快速获得某个攻击面的系统化方法论，而不是从零拼凑零散知识。

技术亮点：最值得关注的是“按需加载”的设计——技能基于对话触发词动态注入，避免了把所有安全知识塞进系统提示导致的上下文膨胀，这是对 LLM 上下文经济性的一种务实利用。其次，项目把安全方法论拆解为标准化、可版本控制的 Markdown 技能单元，便于社区贡献和组合复用；Python 主要用于安装脚本和工具链整合。

上手建议：先阅读 Overview 和 Categories 表，明确自己关注的攻击面；然后按 Quickstart 用 `git clone` 到 `~/.claude/skills/claude-red` 或通过 `./install.sh --category web` 只装需要的类别。贡献方面，建议从某个具体技能（如 `offensive-sqli`）的 SKILL.md 结构入手，遵循现有格式补充技术细节、工具和边界案例，再提交 PR。注意所有技能应仅用于合法授权场景。

#7 Python NEW

VoxCPM

VoxCPM2: Tokenizer-Free TTS for Multilingual Speech Generation, Creative Voice Design, and True-to-Life Cloning

Stars **40,069** Forks **4,557** Today **+144**

https://github.com/OpenBMB/VoxCPM

项目简介：VoxCPM2 是 OpenBMB 团队推出的开源文本转语音（TTS）系统，核心卖点是"无分词器（tokenizer-free）"——它跳过了传统 TTS 将语音离散化为 token 的步骤，直接通过扩散自回归架构生成连续语音表示。项目目标是解决多语言、高自然度语音合成以及声音克隆、声音设计等多样化需求，并已积累超 4 万星标，属于当前 TTS 领域的高关注度项目。

核心功能：一是 30 语言多语种合成，无需语言标签即可直接输入合成，还覆盖四川话、粤语等 9 种中文方言；二是"声音设计"，仅凭自然语言描述（性别、年龄、情绪、语速等）就能凭空创造全新音色，无需参考音频；三是可控声音克隆，用短参考片段克隆音色，并可叠加风格引导来调节情绪与节奏；四是 48kHz 录音棚级输出，接受 16kHz 参考音频直接升采样输出，内置超分无需外部工具。

适用场景：内容创作者和播客/短视频制作者可用它做多语言配音与音色定制；有声书、游戏 NPC 配音、虚拟人场景可借助声音设计与克隆快速产出多样化角色声音；企业做多语种客服、无障碍朗读（TTS 播报）也适合，Apache-2.0 协议允许商用是关键优势。

技术亮点：架构上采用扩散自回归直接建模连续语音表示，绕开离散 token 带来的信息损失，这是其自然度和表现力的根本来源；骨干网络基于 MiniCPM-4，2B 参数、200 万小时多语种数据训练；工程侧支持实时流式，RTF 在 RTX 4090 上低至约 0.3，经 Nano-vLLM/vLLM-Omni 加速可到约 0.13，并提供 OpenAI 兼容 API，落地部署友好。

上手建议：先访问 Hugging Face 上的在线 Demo 或 DemoPage 试听效果，确认音质与语言覆盖是否满足需求；然后在本地按 ReadTheDocs 文档安装推理依赖、下载 VoxCPM2 权重跑通基础合成。若要贡献，可从文档完善、多语言/方言数据评测、推理性能优化（如 vLLM 集成）入手；商用前务必确认 Apache-2.0 条款及模型权重的具体许可说明。

#8 JavaScript NEW

node

Node.js JavaScript runtime ✨🐢🚀✨

Stars **122,651** Forks **39,937** Today **+93**

https://github.com/nodejs/node

项目简介：Node.js 是一个开源、跨平台的 JavaScript 运行时环境，让开发者能在浏览器之外（如服务器、命令行工具、桌面端）运行 JavaScript。它解决了 JavaScript 只能在前端浏览器中执行的问题，把 JS 生态扩展到后端与全栈开发，是目前最主流的服务端 JS 运行平台之一。

核心功能：① 基于 V8 引擎的 JavaScript 执行能力，支持服务端运行；② 内置模块化标准库（文件、网络、加密、流等），无需第三方框架即可构建服务；③ 完善的发布体系（Alpha / Current / LTS / Nightly 四类版本），兼顾尝鲜与生产稳定；④ 二进制发布带 PGP 签名与 SHA 校验，保障供应链安全；⑤ 开放的治理模型（TSC + OpenJS 基金会），社区协作与贡献流程规范。

适用场景：Web 后端服务、API 网关、CLI 工具、构建脚本与前端工具链（如打包器、脚手架）、实时通信（WebSocket）以及微服务等。选择 LTS 版本可用于生产环境，Alpha/Current 更适合库作者和 CI 管线提前适配新特性。

技术亮点：底层依托 V8 提供高性能 JS 执行，并通过 C++ 绑定暴露操作系统能力；采用语义化版本管理，且从 Node.js 27 起改为每年 4 月发布新主版本、10 月转 LTS 的新节奏（此前为每 6 个月一版、仅偶数版转 LTS），LTS 提供约 30 个月支持、总生命周期 36 个月；发布产物经 CITGM 生态兼容性测试和签名校验，工程严谨度较高。

上手建议：普通使用者直接从官网下载 LTS 版本并阅读 `nodejs.org/api` 文档即可；想深入源码或贡献代码，先阅读 `CONTRIBUTING.md`、`GOVERNANCE.md` 与行为准则，从文档修正、测试补充或 `good first issue` 入手，并关注 TSC 与 Collaborators 的协作流程。

数据来源：github.com/trending

报告日期：2026-10-23

由 DeepSeek AI 提供智能分析 | 自动生成